

■■ Incident Investigation Report (SOC Tier 2)

Incident ID	INC-2026-9182	Severity	CRITICAL
Status	Investigating	Category	Identity Abuse / MFA Bypass
Assigned Analyst	Tier 2 Analyst	Investigation Date	September 18, 2026

1. Executive Summary

On **September 18, 2026**, the Splunk SIEM generated a critical behavioral alert pattern mapping a successful **MFA Fatigue / Push Bombing** account bypass technique. An unauthenticated threat actor leveraging an unclassified network asset (**192.168.40.2**) systematically bombarded an authenticated user account (**victim_user**) with high-frequency secondary verification pushes. Following sustained notification strain, the targeted identity asset yielded to authentication fatigue and approved the prompt request transaction, yielding complete session control across exposed target web application vectors. Containment protocols have been actively executed to restrict lateral domain movement.

2. Timeline of Events (Incident Lifecycle)

Timestamp (UTC)	Source Host / IP	Target Account	Log Status	Event Description / Telemetry Matrix
09:47:30.575	192.168.40.2	victim_user	MFA_Prompt_Sent	Initial Attack Vector: Automated loop validates primary credentials. First push challenge issued.
09:47:30.576	192.168.40.2	victim_user	HTTP 202	Authentication node issues asynchronous pending token validation state codes.
09:47:31 - 39	192.168.40.2	victim_user	MFA_Prompt_Sent	Sustained Push Storm: 14 sequential verification requests submitted via a rapid 2-second offset cadence.
09:47:41.410	Device Endpoint	victim_user	MFA_Approved	Compromise Point: Exhausted identity asset transmits confirmation token validation signature.
09:47:41.410	192.168.40.2	victim_user	HTTP 200	Access Granted: Application context binds session tokens. Attacker provisions active authentication cookies.

3. Technical Evidence & SIEM Correlation Data

Raw Ingested Log Telemetry:

```
2026-09-18 09:47:30,575 - INFO - status=MFA_Prompt_Sent user=victim_user src_ip=192.168.40.2 msg='Push notification sent to user device'
2026-09-18 09:47:41,410 - INFO - status=MFA_Approved user=victim_user src_ip=192.168.40.2 msg='User approved the push notification'
```

Our custom behavioral correlation search parsed the unstructured streams into metric indicators across a tight 5-minute sampling threshold:

- **Total MFA Pushes Transmitted (total_prompts):** 15 prompts
- **Total Approvals Logged (approved_prompts):** 1 approval

- **Resulting Action:** True Positive Signature Match.

4. Root Cause Analysis (RCA)

1. **Credential Compromise:** The malicious actor acquired valid employee directory passwords prior to deployment, likely using info-stealer malware extractions or targeted phishing repositories.
2. **Policy Flaw:** The baseline application authentication portal lacked rate-limiting bounds, allowing an infinite number of rapid concurrent verification calls to stack against single identity targets.
3. **Human Variable:** The end-user intentionally cleared the prompt stream to silence mobile notifications out of deep interface irritation.

5. Containment & Remediation Actions (L2 Playbook)

- **Session Invalidation (Completed):** Invoked API hooks across the core directory controller to invalidate all active OAuth refresh tokens and terminate running web sessions for *victim_user*.
- **Account Lock (Completed):** Enforced directory-level account lockouts and triggered an administrative password expiration script. The account remains isolated pending out-of-band identity checks.
- **Network Quarantine (Pending):** Perimeter firewall change ticket submitted to block external traffic blocks tracing back to 192.168.40.2.
- **Downstream Threat Hunt (Active):** Querying log streams to track post-compromise activity, checking for container configuration edits, unauthorized database calls, or data staging markers.

6. Strategic Engineering Recommendations

- Enforce mandatory **MFA Number Matching** architecture to stop systemic or reflexive out-of-band mobile verification taps.
- Implement rigid **Identity Rate-Limiting Controls** to automatically lock down auth paths if more than 5 push tokens clear inside a 60-second time vector.

This is for informational purposes only. For medical advice or diagnosis, consult a professional. AI responses may include mistakes.